IS Audit & Control

Abdul-Rahman Mahmood
Assistant Professor, Computer Science, FAST-NU

abdulrahman@nu.edu.pk
alphapeeler.sf.net/pubkeys/pkey.htm
pk.linkedin.com/in/armahmood
bqb-tsid-asp
alphapeeler
alphapeeler
armahmood786
http://alphapeeler.sf.net/
reddit.com/user/alphapeeler
www.flickr.com/alphapeeler
http://alphapeeler.tumblr.com
armahmood786@jabber.org
alphapeeler@aim.com
abdulmahmood-sss
alphapeeler@icloud.com
pinterest.com/alphapeeler

Auditing Unix and Linux Operating Systems

Part 3

Objectives

- • How to audit Unix and Linux systems, focusing on the following main areas:
- • Account management and password controls
- • File security and controls
- • Network security and controls
- • Audit logs
- • Security monitoring and general controls
- • Tools and resources for enhancing your *nix audits

Test Steps for Auditing *nix

- The following audit steps are divided into five sections:
  • Account management and password controls
- • File security and controls
- • Network security and controls
- • Audit logs
- • Security monitoring and general controls

Test Steps for Auditing *nix

- 14. Review and evaluate the security of directories in root's path. Evaluate the usage of the "current directory" in the path.
  - review the permissions of each directory using the ls -ld command.
  - The following will print the permissions of root's path (assuming that the script is executed as root) and warn if there is a "." in the path or if one of the directories is world writable:

```
#!/bin/sh
for i in `echo $PATH | sed 's/:/ /g'`
do
if [ "$i" = . ]
then
echo -e "WARNING: PATH contains .\n"
else
ls -ld $i
ls -ld $i | awk '{if(substr($1,9,1)=="w")print "\nWARNING -
" $i " in root'\''s' path is world writable"}'
fi
done
```

Test Steps for Auditing *nix

- **15. Review security of home directories and config files. They should be writable only by owner.**
  - User config files(***dot-files***): located in home directory,.
  - At login, commands executes in .login, .profile, .bashrc.
  - .cshrc and .kshrc, are executed when new shell is run, or when su command is used to switch to user's account.
  - If attacker modify (.) files, he can insert his commands, and at next login user will execute those commands.
  - ls –ld command should be performed on each directory to view directory permissions. The ls –al command should be performed on each directory to view the permission on the files (including the config files) within the directory.

File Security and Controls

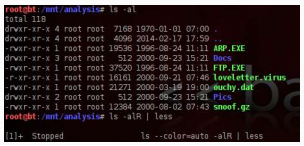
Test Steps for Auditing *nix

- **16. Evaluate the file permissions for critical files and their related directories.**
  - /bin, /usr/bin, /sbin, /usr/sbin, and/or /usr/ocal/bin
  - /etc (system configuration files)
  - /usr or /var (contain various accounting logs)
  - ls -alR command (recursive file listing) against the entire file system and place the results in a file for you.
  - if you want to find all world-writable files (excluding symbolic links, or symlinks), use :

```
find / -perm -777 ! -type l -print.
```

Test Steps for Auditing *nix

- **17. Look for open directories (with permission set to drwxrwxrwx) on the system and determine whether they should have the sticky bit set.**
  - This is sometimes appropriate for **/tmp** directories and other repositories for noncritical, transitory data;



  - In the listing of ls –alR, note that the directory permissions will be listed next to the ".".)
  - To find just directories with worldwrite permissions, you can use the command find / -type d –perm -777.

Test Steps for Auditing *nix

- **18. Evaluate the security of all SUID files on the system, especially those that are SUID to "root."**
  - SUID files allow users to execute them under the privileges of another UID. Giving temporary permissions to a user to run a program/file with the permissions of the file owner rather that the user who runs it.
  - Set SUID bit using the following commands:
    find / -perm -u+s OR **chmod 4750 file1.txt**
  - Before setting SUID bit:
  - `ls -l total 8 -rwxr--r-- 1 xyz xyzgroup 148 Dec 22 03:46 file1.txt`
  - After setting SUID bit:
  - `ls -l total 8 -rwsr--r-- 1 xyz xyzgroup 148 Dec 22 03:46 file1.txt`

Test Steps for Auditing *nix

- 19. Review and evaluate security over the kernel.
  - Use the ls –l command on the location of the kernel for the system you are auditing.
  - It should be owned and writable only by the superuser.
  - The kernel could be stored in a number of possible locations. Some common kernel names are /unix (AIX), /stand/ vmunix (HP), /vmunix (Tru64), /kernel/genunix (Solaris), and /boot/vmlinuz (Linux).

Test Steps for Auditing *nix

- 20. Ensure that all files have a legal owner in the /etc/passwd file.
  - When a file is created, it is assigned an owner. If that owning account is deleted, UID of that account still will be listed as the owner of the file unless ownership is transferred to a valid account. If another account is created later with that same UID, the owner of that account will, by definition, be given ownership of those files.
  - Perform the **quot** command.
  - Display total block usage per user for a file system
  - quot command is not available on all versions of Linux.
  - Use ls -alR command to see if any files list an invalid username as the owner.

Test Steps for Auditing *nix

- 21. Ensure that the chown command cannot be used by users to compromise user accounts.
  - Thechown command allows users to transfer ownership of their files to someone else. If a user can transfer an SUID file to another user, he or she then will be able to execute that file and "become" the user.
  - Steps to ensure:
  - 1. Review the password file and determine where your shell is located (e.g., /bin/csh or /usr/bin/sh).
  - 2. Create a copy of your shell file in your home directory: cp <shell file name> ~/myshell
  - 3. Make your new shell file SUID and world executable. chmod 4777 ~/myshell

Test Steps for Auditing *nix

- 4. Choose another user from the password file to transfer ownership to, preferably a fellow auditor.
- 5. Run the command chown <new owner name> ~/myshell, which will attempt to transfer ownership of the file to another user.
- 6. Run the command ls -l ~/myshell to see whether you transferred ownership successfully and, if so, whether the SUID bit also transferred.
- 7. If the SUID bit transferred to another owner, execute the file by typing /myshell. This will execute the shell.
- 8. Run the command whoami. This should show that you are now the other user and have taken over his or her account.
- 9. If this happens, the system administrator will need to contact his or her vendor for a fix.

Test Steps for Auditing *nix

- 22. Obtain and evaluate the default umask value for the server.
  - The umask determines what permissions new files and directories will have by default.
  - In other words, with a umask of **000**, all new files and directories will be created with default permissions of 777 (777 minus 000), meaning full access for the owner, group, and world. For example, if the umask is set to 027, it will result in the following default permissions for newly created files and directories:
  - Normal default 777
  - Minus the umask 027
  - Default permissions on this server 750

Test Steps for Auditing *nix

- 23. Examine the system's crontabs, especially root's, for unusual or suspicious entries.
  - A cron executes a program at a preset time. It is basically the Unix or Linux system's native way of letting you schedule jobs
  - The crontabs should be located within directory /usr/spool/cron/crontabs or /var/ spool/cron/crontabs. By performing the ls –l command on this directory, you will be able to list the contents.

Test Steps for Auditing *nix

- 24. Review security of files referenced within crontab entries, particularly root's. Ensure the entries refer to files that are owned and writable only by the owner and are located in directories that are owned by and writable only by the owner of the crontab.
  - The ls -l command should be performed on each file being executed in a crontab, and the ls –ld command should be executed for each of the directories containing those files.
- 25. Examine the system's scheduled atjobs for unusual or suspicious entries.
  - The atjobs should be located within directory /usr/spool/cron/atjobs or /var/spool/ cron/atjobs. Perform "ls –l" on this directory, to list the contents.

Network Security and Controls

Test Steps for Auditing *nix

- 26. Determine what network services are enabled on the system, and validate their necessity with the system administrator. For necessary services, review and evaluate procedures for assessing vulnerabilities associated with those services and keeping them patched.
  - Use the netstat –an command, and look for lines containing LISTEN or LISTENING.
  - To validate a specific patch or package run: rpm -q -a (Red Hat or other distributions using RPM) or dpkg --list (Debian and related distributions) will show the versions of installed packages.

Test Steps for Auditing *nix

```
[root@rhel54x64 sgupta]# netstat -a
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address               Foreign Address             State
tcp        0      0 *:nfs                       *:*                         LISTEN
tcp        0      0 *:mysql                     *:*                         LISTEN
tcp        0      0 *:netbios-ssn               *:*                         LISTEN
tcp        0      0 *:39533                     *:*                         LISTEN
tcp        0      0 *:dhcp-failover2            *:*                         LISTEN
tcp        0      0 *:sunrpc                    *:*                         LISTEN
tcp        0      0 *:ftp                       *:*                         LISTEN
tcp        0      0 127.0.0.1:ipp               *:*                         LISTEN
tcp        0      0 *:anf-secure-zmcp           *:*                         LISTEN
tcp        0      0 *:microsoft-ds              *:*                         LISTEN
tcp        0      0 *:703                       *:*                         LISTEN
tcp        0      0 rhel54x64.ind.:microsoft-ds sgupta:57182                ESTABLISHED
tcp        0      0 *:http                      *:*                         LISTEN
tcp        0      0 *:ssh                       *:*                         LISTEN
tcp        0      0 localhost6.localdomain6:ipp *:*                         LISTEN
tcp        0      0 *:https                     *:*                         LISTEN
tcp        0      0 *:pcsync-https              *:*                         LISTEN
tcp        0    500 rhel54x64.ind.com:ssh       sgupta:57925                ESTABLISHED
udp        0      0 *:nfs                       *:*
udp        0      0 rhel54x64.in:netbios-ns     *:*
udp        0      0 *:netbios-ns                *:*

[root@rhel54x64 sgupta]#
```

Test Steps for Auditing *nix

- 27. Execute a network vulnerability-scanning tool to check for current vulnerabilities in the environment.
  - www.nessus.org and www.openvas.org, NMAP, Tiger and TARA, Crack and John the Ripper etc.
- 28. Evaluate usage of **trusted access** via the /etc/hosts.equiv file & .rhosts files. Ensure that trusted access is not used.
  - If system "Trusting" has an /etc/hosts.equiv file that lists machine "Trusted" as a trusted host, then any user with an account using the same username on both systems will be able to access "Trusting" machine without the use of a password.
  - To find .rhosts files, you will need to view the contents of each user's home directory via the ls –l command

Test Steps for Auditing *nix

- 29. Review and evaluate the usage of trusted access via SSH keys.
  - Trusted access via SSH keys is almost same as trusted access via .rhosts files discussed in preceding step.



Test Steps for Auditing *nix

- 30. If anonymous FTP is enabled and genuinely needed, ensure that it is locked down properly.
  - Check for an "ftp" account in the password file and if the FTP service is enabled, then anonymous FTP is available on the system. Once an anonymous FTP user has logged in, he or she is restricted only to those files and directories within the "ftp" account's home directory
  - Ensure that the FTP directory (/ftp) is owned and writable only by "root" and not by ftp.
  - The **/ftp directory** and its other subdirectories should be set with permissions at least as as **dr-xr-xr-x** so that users can't delete and replace files

Test Steps for Auditing *nix

- 31. If NFS is enabled and genuinely needed, ensure that it is secured properly.
  - NFS use can be verified by examining the /etc/exports file or the /etc/dfs/dfstab file (using the more command). If this file shows that file systems are being exported, then NFS is enabled.
  - Ensure that the **access=** option is used on each file system being exported.
- 32. Review for the use of secure protocols.
  - Disable telnet,ftp, and/ or the "r" commands and replacing them with secure alternatives. Telnet, rsh, and rlogin can be replaced by SSH; FTP can be replaced by Secure File Transfer Protocol (SFTP) or Secure Copy Protocol (SCP); and rcp can be replaced by SCP.